

How to integrate a Virus Scanner into your Pipelines

What is a supply chain attack?

- A cyber-attack that seeks to damage an organization by targeting elements in the software supply chain.
- Cybercriminals typically manipulate the distribution of a product by installing malware.
- Attacks exploiting the software supply chain, in which an low-level or unimportant software component used by other software is used to inject malicious code into the larger software that depends on the component.
- Supply chain attack poses a significant risk to modern day organizations.
- Targets the 5 pillars of information security

source: Wikipedia

Five Pillars of Information Security



Extended Pillars:

- Authenticity
- Non-repudiation

source: The Five Pillars of Information Security: CIA Triad and More

History

Here is a timeline of notable supply chain attacks:

- **2015:** The XCodeGhost attack compromised the iOS development tool, infecting apps with malware and affecting Chinese developers. 
- **2017:** A significant jump in supply chain attacks was observed, marking a turning point in their prevalence. 
- **2018:** The Taiwanese chip manufacturer TSMC was hit by malware that spread through its software update system. 
- **2020:** The SolarWinds breach led to a widespread compromise of numerous government agencies and private companies after hackers infiltrated its software update mechanism. 
- **2021:** Attacks against open-source software grew by a massive 650% year-on-year, indicating a shift in attacker focus. 
- **2022:** The NotPetya attack, originating from a Ukrainian tax software, disrupted global logistics when it infected Maersk, the world's largest container shipping company. 
- **October 2023:** Okta, a prominent identity and access management provider, suffered a breach through attacks on its customer support system. 
- **August 2024:** A malicious PyPI package named "solana-py" was released, designed to steal crypto wallet keys. 
- **October 2024:** The popular JavaScript library and npm package Lottie Player was compromised, with malicious versions released by threat actors. 
- **February 2024:** A major ransomware attack on Change Healthcare, a health payment processor, disrupted operations and exposed millions of patient records. 
- **May 11, 2026 (Mass npm & PyPI Poisoning):** A massive supply chain attack injected malicious versions of popular packages (including TanStack, Mistral AI, and UiPath) to steal AWS, GitHub, and npm credentials, propagate poisoned configurations into IDEs, and exfiltrate data via Tor.
- **April 22, 2026 (Xinference Compromise):** The AI framework Xinference was compromised in a campaign attributed to the "TeamPCP" threat actor.
- **March 20–24, 2026 (Trivy & KICS Breaches):** Threat actor TeamPCP struck again by compromising trusted open-source tools—Aqua Security's Trivy and Checkmarx's KICS—in a series of high-profile supply chain breaches.
- **February 2025 – Early 2026 (CI/CD Credential Harvesting):** A wave of compromises hit developer platforms and action repositories. Attackers targeted tooling such as `tj-actions/changedfiles` and the widely used `Polyfill.io` domain, injecting code to hijack websites and cloud environments.
- **September 2025 (npm Ecosystem Attack):** Attackers broke into trusted and widely-used npm packages like `chalk` and `debug`. They injected malicious code directly into new versions, allowing the threat to spread rapidly into developer environments.
- **2024 (LLM and PyPI Typosquatting):** Throughout 2024, attackers frequently targeted the Python Package Index (PyPI). Hackers uploaded hundreds of malicious packages mimicking legitimate AI and LLM libraries to install backdoors (like JarkaStealer) onto victims' systems.  Securelist +5

What is ClamAV?

- ClamAV is an open-source antivirus engine
- for detecting trojans, viruses, malware
- other malicious threats



Dockerfile, entrypoint.sh

```
FROM clamav/clamav:stable                                     #!/bin/sh

RUN apk upgrade --no-cache \                                  set -eu
    && apk add --no-cache clamav \
    && echo "DetectPUA yes" >> /etc/clamav/clamd.conf

COPY entrypoint.sh /entrypoint.sh

USER clamav:clamav

HEALTHCHECK none

ENTRYPOINT ["/entrypoint.sh"]

touch /var/log/clamav/clamd.log
tail -f /var/log/clamav/*.log &

freshclam --quiet

clamd &

while [ ! -S /tmp/clamd.sock ]; do
    sleep 1
    echo -ne `date`"\r"
done

clamdscan --multiscan /var/www
```

GitHub

```
jobs:
  build:
    name: Clamav
    runs-on: ubuntu-latest
    timeout-minutes: 10

  steps:
    - uses: actions/checkout@v4

    - name: Build containers
      run: |
        # setup composer, npm
        docker build -t clamav .
        composer install --no-scripts
        npm ci --ignore-scripts
        docker run --rm -it -v $(pwd):/var/www clamav
```

GitLab

```
clamav-test-job:
  stage: test
  image: debian:bookworm-slim
  tags:
    - saas-linux-large-amd64
  script:
    # setup php, npm
    - apt-get -y --no-install-recommends install clamav-daemon clamdscan
    - sed -i 's/DetectPUA false/DetectPUA true/' /etc/clamav/clamd.conf \
    - sed -i "s/User clamav/User root/" /etc/clamav/clamd.conf \
    - mkdir -m 0777 /var/run/clamav \
    - composer install --no-scripts
    - npm ci --ignore-scripts
    - composer audit
    - npm audit
    - freshclam
    - clamd &
    - while [ ! -S /var/run/clamav/clamdctl ]; do sleep 1; echo -ne `date`"\r"; done
    - clamdscan --multiscan .
  dependencies: [build-job]
```


Testing

- Download an eicar test file from <https://www.eicar.org/download-anti-malware-testfile/>
- Push the test file to your repository
- Verify the results in your pipeline

```
Thu Sep 25 16:38:37 2025 -> /var/www/eicar.txt: Eicar-Signature FOUND  
  
----- SCAN SUMMARY -----  
Infected files: 1  
Time: 90.910 sec (1 m 30 s)  
Start Date: 2025:09:25 16:38:37  
End Date: 2025:09:25 16:40:08
```

Resources

- ClamAV: <https://www.clamav.net>
- Hardening GitHub Actions workflows:
<https://phpunit.expert/articles/hardening-github-actions-workflows.html>
- zizmor: <https://docs.zizmor.sh>